Lab 52 — Security Awareness: Phishing Simulation

> **SY0-701 Objective 5.6** — Given a scenario, implement security awareness practices
>
> **Domain 5** — Security Program Management and Oversight (20%) · **Time:** ~20 min · **Course:** TGS-2023039181 CompTIA Security+ (SY0-701)

Goal: Run a controlled phishing simulation end-to-end and turn the metrics into training, not blame.

You'll build: A GoPhish campaign delivering to an internal MailHog SMTP sink, with tracked open and click metrics mapped to awareness actions.

> **Use only against accounts and domains you control.** Deliver all simulated mail to the local MailHog sink in this playground — never to real recipients without written sponsorship from HR, legal and leadership.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; tools installed in steps 1 and 4.

Background

- People are a control surface; a **security awareness program** trains them to recognise, resist and report attacks.
- **Phishing campaigns** measure and improve how users respond; the four GoPhish primitives are a sending profile, an email template, a landing page and a target group.
- **Anomalous behaviour** falls into risky (knowingly unsafe), unexpected (out of pattern) and unintentional (honest mistake).
- The program lifecycle is **development**, **execution**, then **reporting and monitoring** — initial at onboarding and recurring refreshers.
- Metrics drive **training**, never discipline; the goal is to raise the **report rate** and lower the **click rate** over time.

Steps

1. Download and unzip the GoPhish binary

GoPhish ships as a single Go binary.

```
apt-get update -qq && apt-get install -y unzip curl
mkdir -p /opt/gophish && cd /opt/gophish
curl -sLO https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
unzip -o gophish-v0.12.1-linux-64bit.zip && chmod +x gophish
```

2. Bind the admin UI for the playground

Expose the admin UI so you can reach it from the Killercoda tab (lab only).

```
cd /opt/gophish
sed -i 's/127.0.0.1:3333/0.0.0.0:3333/' config.json
grep admin_server config.json
```

3. Start GoPhish and note the admin password

GoPhish prints an auto-generated admin password to stdout on first run.

```
cd /opt/gophish
(./gophish > gophish.log 2>&1 &) ; sleep 5
grep -iE "please login|admin|password" gophish.log | head -3
```

Open `https://<killercoda-host>:3333`, log in as `admin` and set a new password.

4. Spin up the MailHog SMTP sink

MailHog captures all outbound mail so nothing reaches a real inbox.

```
apt-get install -y docker.io && (service docker start || systemctl start docker)
docker run -d -p 1025:1025 -p 8025:8025 mailhog/mailhog
docker ps | grep mailhog
```

5. Configure the four GoPhish primitives

In the UI, create: a **Sending Profile** pointing at host `127.0.0.1:1025` (MailHog); an **Email Template** ("Password expiry — please reset") containing a `{{.URL}}` token; a **Landing Page** that records clicks (never capture real passwords); and a **Users & Groups** list of opted-in test addresses only.

6. Launch the campaign and watch the dashboard

Create and launch the campaign, then watch the dashboard track sent, opened (tracking pixel), clicked and submitted.

7. Map click and report rates to training actions

Convert metrics into education, not punishment.

```
Click rate < 5%   -> quarterly refresh only
Click rate 5-15%  -> targeted micro-learning
Click rate > 15%  -> mandatory training + manager comms
Report rate       -> drive this UP (reward reporting, including false alarms)
```

Test it

```
curl -s http://127.0.0.1:8025/api/v2/messages | head -c 200; echo
docker ps | grep -q mailhog && echo "MailHog sink running"
```

Expected: the GoPhish dashboard tracks sent/opened/clicked; simulated emails appear in the MailHog UI (`http://<host>:8025`) rather than a real inbox; and the click/report rates map to a training action.

Troubleshooting

Symptom	Fix
Admin password not in the log	It only prints on first run; delete `gophish.db` and restart to regenerate.
Browser blocks the self-signed cert	Expected; accept the GoPhish admin cert to continue (lab only).
No mail in MailHog	Check the sending profile host is `127.0.0.1:1025` and the MailHog container is running.

Challenge

Design a second, harder campaign and explain how you would keep it ethical — which pretexts (bonuses, redundancies, bereavement) you would rule out, and why.

Reflection

Objective 5.6 names reporting and monitoring, initial and recurring. Why is the *report rate* a better long-term measure of a healthy security culture than the click rate alone?

Exam tips

- The four GoPhish primitives: sending profile, email template, landing page, target group.
- Anomalous behaviour: risky (knowingly unsafe), unexpected (out of pattern), unintentional (honest mistake).
- Program lifecycle: development, execution, reporting and monitoring (initial at onboarding, recurring refreshers).
- Simulations exist for education; a blame-free, one-click-report culture surfaces real attacks fastest.

References

- GoPhish — https://getgophish.com
- MailHog (safe SMTP sink) — https://github.com/mailhog/MailHog
- CISA phishing guidance — https://www.cisa.gov/topics/cyber-threats-and-advisories/phishing
- Google phishing quiz — https://phishingquiz.withgoogle.com
